



Tecnológico de Monterrey
Escuela de Ingeniería y Ciencias

Reporte Técnico

Guardían Monarca

Sistema de Gestión Segura de Identidades Digitales
para Casa Monarca

Materia:

MA2006B – Uso de Álgebras Modernas para Seguridad y Criptografía (Gpo 603)

Integrantes del equipo:

A00839082 Paola Michelle Martínez Galeazzi
A00838589 Steffany Mishell Lara Muy
A01198777 Andrés Alarcón Navarro
A00840131 María Paula Recinos Rios
A00838606 Santiago Dueñas Sanchez
A01424357 Patricio Mourra Cossio

Profesor:

Alberto F. Martínez

Junio de 2026

Índice de Contenidos

1. Introducción	2
2. Contexto y planteamiento del problema	2
3. Marco teórico y legal	3
3.1. Marco legal: LFPDPPP y Derechos ARCO	3
3.2. Infraestructura de Clave Pública (PKI)	3
3.3. Curvas elípticas y ECDSA P-256	3
4. Arquitectura del sistema	4
4.1. Stack tecnológico	5
5. Algoritmos criptográficos implementados	5
6. Sistema de roles y control de acceso	6
6.1. Flujo de autenticación	6
6.2. Interfaces diferenciadas por rol	7
7. Cadena de custodia con multi-firma ECDSA	8
8. Módulo de Derechos ARCO	9
9. Log de auditoría	11
10. Protocolos para escenarios críticos	12
11. Pruebas del sistema	13
12. Alineación con los ODS	13
13. Reflexión ética	14
14. Mejoras para versión 2	14
15. Conclusiones	14
16. Repositorio	15
17. Referencias bibliográficas	15

Introducción

La migración en México es una realidad que no puede ignorarse. El 66 % de los migrantes extranjeros que se encuentran en el país y no lograron cruzar hacia Estados Unidos ahora desean establecerse definitivamente aquí (ACNUR, 2025). Esto genera un reto tanto para quienes migran como para las comunidades que los reciben, cuyas consecuencias políticas, económicas y sociales afectan a millones de personas. Pese a eso, existen organizaciones que han decidido no quedarse de brazos cruzados.

Casa Monarca, ubicada en Monterrey, Nuevo León, es una de ellas. Se trata de una organización sin fines de lucro cuyo objetivo es acoger, proteger, promover e integrar a migrantes internos, deportados y personas con necesidad de protección internacional. La organización maneja información extremadamente sensible, dado que almacena nombres, países de origen, estatus legal y documentos de identidad de personas que ya de por sí se encuentran en situación vulnerable. Proteger esa información no es opcional, la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y los Derechos ARCO lo exigen legalmente. Y un incidente previo en la organización, donde un colaborador eliminó información al salir sin que nadie pudiera rastrearlo, dejó en evidencia la urgencia de actuar.

Guardían Monarca nace como respuesta a esa necesidad. No se reduce a una aplicación web convencional, sino a una plataforma que combina autenticación con certificado digital X.509, control de acceso basado en roles, firmas digitales ECDSA sobre curvas elípticas P-256 y un registro inmutable de cada acción crítica. El resultado, en términos prácticos, es que solo el personal autorizado, desde el dispositivo correcto, puede acceder a los expedientes de personas migrantes. Y cada operación sensible queda firmada criptográficamente con evidencia verificable. El presente reporte documenta la fundamentación teórica, la arquitectura, la implementación técnica y las pruebas que se realizaron sobre el sistema.

Contexto y planteamiento del problema

Para comprender por qué Guardían Monarca se diseñó de la manera en que lo hicimos, es necesario entender las problemáticas que Casa Monarca enfrentaba en su operación diaria. Por una parte, los datos personales de los migrantes se almacenaban sin ningún tipo de protección criptográfica, lo cual los exponía a filtraciones. Por otra parte, el control de acceso era prácticamente inexistente, como lo demostró el incidente donde un colaborador pudo borrar información de forma unilateral al salir de la organización. Nadie pudo rastrear quién lo hizo ni qué datos se perdieron. Asimismo, la LFPDPPP y los Derechos ARCO exigen mecanismos formales de gestión y protección de datos personales que la organización simplemente no tenía implementados.

Con respecto a la infraestructura, Casa Monarca cuenta con el Plan Negocios de HostGator, que provee 50 GB de almacenamiento, hasta 25 conexiones simultáneas a MySQL, acceso SSH, SSL gratuito con Let's Encrypt y tareas cron para respaldos. Esto nos permitió desplegar todo sin costo adicional para la organización, lo cual es fundamental dado que no tienen presupuesto disponible para tecnología. Es decir, la solución debía funcionar con lo que ya existía.

Marco teórico y legal

3.1 Marco legal: LFPDPPP y Derechos ARCO

El sistema debe cumplir con la LFPDPPP y con los Derechos ARCO, que son cuatro: Acceso, que permite consultar qué datos se tienen almacenados. Rectificación, que permite corregir datos incorrectos. Cancelación, que permite solicitar la eliminación cuando ya no son necesarios. Y Oposición, que permite negarse a que los datos se utilicen para ciertos fines. Dado que los beneficiarios de Casa Monarca son personas en situación de vulnerabilidad, la correcta implementación de estos derechos no se reduce a un requisito legal, es también una responsabilidad ética que como ingenieros debemos asumir.

3.2 Infraestructura de Clave Pública (PKI)

Una PKI es el conjunto de roles, políticas y procedimientos para crear, gestionar, distribuir y revocar certificados digitales (Menezes, van Oorschot y Vanstone, 1997). En nuestro sistema, la PKI se compone de tres elementos. La Autoridad Certificadora es propia de Casa Monarca, generada con la librería `cryptography` de Python, y su clave raíz es RSA de 4096 bits. Los certificados X.509 contienen la identidad del titular, su clave pública, el correo electrónico en el campo SAN y la firma digital de la CA. En lugar de una CRL formal, el sistema mantiene una tabla en MySQL llamada `certificados_revocados` que Flask consulta cada vez que alguien intenta autenticarse.

3.3 Curvas elípticas y ECDSA P-256

La criptografía de curvas elípticas es el fundamento matemático que sostiene todas las firmas digitales del sistema (Otero Fadul, 2026). Una curva elíptica sobre un campo primo $\mathbb{F}_p$ se define como:

$$E(\mathbb{F}_p) : y^2 \equiv x^3 + ax + b \text{ mód } p$$

Para P-256, también conocida como `secp256r1`, el primo p tiene 256 bits y el grupo de puntos tiene orden primo $n \approx 2^{256}$. La seguridad se basa en que, dado un punto $Q = d \cdot G$ donde G es el generador estándar, calcular d a partir de Q y G es computacionalmente intratable. A este problema se le conoce como el Problema del Logaritmo Discreto en Curvas Elípticas (Otero Fadul, 2026, Sección 3.1).

Cada usuario tiene un par de claves elípticas. La clave privada es un entero aleatorio $d \in \mathbb{Z}_n$ de 256 bits que vive dentro del archivo `.p12` protegido con AES-256. La clave pública es el punto $Q = d \cdot G$ sobre la curva, almacenado en MySQL. El algoritmo ECDSA produce una firma (r, s) sobre un mensaje m de la siguiente manera (Otero Fadul, 2026, Sección 3.3.2):

$$\begin{aligned} k &\leftarrow \text{aleatorio en } \mathbb{Z}_n \\ r &= (k \cdot G)_x \text{ mód } n \\ s &= k^{-1}(H(m) + d \cdot r) \text{ mód } n \end{aligned} \tag{1}$$

donde H es SHA-256. La verificación se realiza calculando:

$$u_1 = s^{-1} \cdot H(m) \text{ mód } n$$

$$u_2 = s^{-1} \cdot r \text{ mód } n$$

$$R = u_1 \cdot G + u_2 \cdot Q$$

y comprobando que $R_x = r$. Si la coordenada x del punto R coincide con r , la firma es válida.

Es evidente que la ventaja de EC P-256 sobre RSA para firmas es la eficiencia. Una clave de 256 bits ofrece seguridad equivalente a una RSA de 3072 bits, y las firmas pesan 512 bits en lugar de 3072. Por tanto, las operaciones son considerablemente más rápidas y los archivos más ligeros.

Arquitectura del sistema

El sistema sigue una arquitectura web de tres capas. La capa de presentación son páginas HTML renderizadas con Jinja2, con cuatro interfaces completamente diferentes según el rol del usuario, CSS responsive y JavaScript con fetch API. La capa de lógica es un servidor Flask en Python 3.12 sin ORM. Todas las consultas usan la función `_exec()` con marcadores `%s` para prevenir inyección SQL. Las sesiones se gestionan con Flask-Session usando backend filesystem y `SESSION_USE_SIGNER` habilitado para firmar las cookies con HMAC-SHA256. La capa de datos es MySQL 8 en producción con más de 15 tablas que cubren usuarios, certificados, migrantes, solicitudes de registro, solicitudes ARCO, log de auditoría, historial de eliminaciones y firmas digitales. El campo ENUM del log registra más de 30 tipos de eventos.

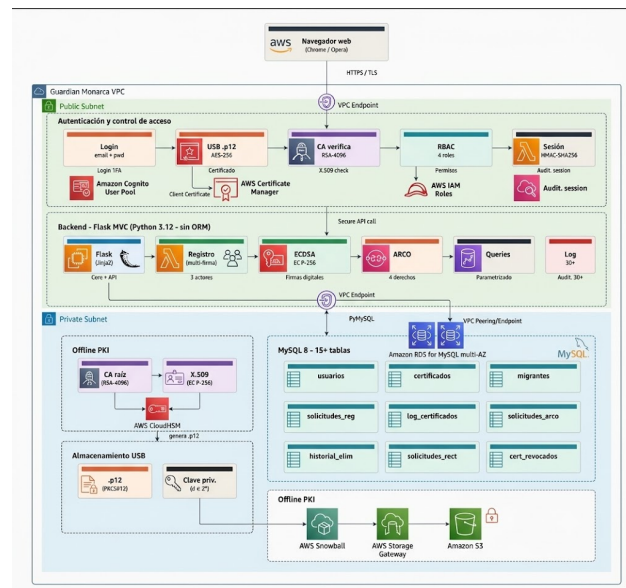


Figura 1: Arquitectura de despliegue de Guardián Monarca. Se observa la segmentación entre la Subred Pública (autenticación) y la Subred Privada (datos y PKI).

Como se aprecia en el diagrama, la infraestructura se organiza en tres niveles de seguridad:

- **Subred Pública (Capa de Autenticación):** Aloja el punto de entrada HTTPS, gestionando la identidad mediante Amazon Cognito y la validación de certificados X.509.
- **Backend (Capa de Aplicación):** Entorno Flask sobre Python 3.12 que integra los módulos de firmas ECDSA P-256 y el motor de gestión de derechos ARCO.
- **Subred Privada (Capa de Datos y PKI):** Zona aislada que contiene la instancia de Amazon RDS (MySQL 8 multi-AZ). La infraestructura de clave pública (PKI) se gestiona de forma híbrida: la clave raíz (RSA-4096) reside en AWS CloudHSM.

4.1 Stack tecnológico

Componente	Tecnología
Lenguaje y framework	Python 3.12 + Flask (MVC)
Base de datos	MySQL 8 (producción), SQLite (desarrollo)
Consultas	PyMySQL, queries parametrizadas con %s
CA raíz	RSA 4096, autofirmada, SHA-256
Claves de usuario	EC P-256 (secp256r1)
Firmas digitales	ECDSA P-256 + SHA-256
Archivos de certificado	PKCS#12 (.p12) con AES-256
Contraseñas	bcrypt con salt único por usuario
Sesiones	Flask-Session (filesystem) + HMAC-SHA256
Frontend	HTML5, CSS3, Jinja2, JavaScript fetch API
Reportes	openpyxl (Excel)

Algoritmos criptográficos implementados

El sistema utiliza seis algoritmos criptográficos y cada uno cumple un rol específico dentro de la arquitectura de seguridad. RSA-4096 genera el par de claves de la CA raíz (Otero Fadul, 2026, Sección 2.1), cuya clave privada nunca sale del servidor y está protegida con contraseña. Su única función es firmar los certificados X.509 que emite el sistema. EC P-256 genera los pares de claves de cada usuario, la pública va a la base de datos y la privada se empaqueta en el .p12 que se le entrega en USB. ECDSA combinado con SHA-256 es el que firma cada operación crítica, es decir, registro de migrantes, aprobaciones, solicitudes ARCO y toda la cadena de custodia. Cada firma queda guardada en base64 junto con la clave pública y el mensaje firmado original.

AES-256 a través de PKCS#12 protege la clave privada del usuario dentro del archivo .p12, de manera que sin la contraseña correcta el contenido es ilegible. bcrypt se encarga de las contraseñas con salt único por usuario, esto garantiza que aunque dos personas tengan la misma contraseña sus hashes serán completamente diferentes. Y HMAC-SHA256 es lo que Flask-Session usa para firmar cada cookie de sesión, de manera que una sesión sin firma válida se rechaza automáticamente.

Sistema de roles y control de acceso

El sistema implementa RBAC con cuatro niveles jerárquicos y cada uno tiene su propio método de autenticación. El Administrador es el coordinador general y responsable de TI, necesita contraseña más archivo .p12 desde USB para entrar, y puede gestionar todos los expedientes, emitir y revocar certificados, aprobar eliminaciones, ver el log completo y cambiar roles. El Coordinador supervisa el trabajo de campo, también usa doble factor, y puede ver y editar todos los expedientes, firmar operaciones con ECDSA y solicitar eliminaciones. El Operativo es el personal de campo con primer contacto con los migrantes, su acceso es con contraseña y certificado validado en BD. El Voluntario es apoyo externo con acceso restringido, solo necesita contraseña y puede capturar expedientes y ver su panel básico.

6.1 Flujo de autenticación

El proceso funciona de la siguiente forma. El usuario ingresa su correo y contraseña en el portal. Si el rol es Admin o Coordinador, el sistema pide además que cargue su .p12 desde USB con la contraseña del archivo. La CA verifica que el certificado X.509 fue firmado por ella, que no está en la tabla de revocados y que no expiró. Si todo está bien, el sistema asigna vistas y permisos según el rol. Cada acción posterior queda en el log con IP, fecha, usuario y tipo de evento. Sin el certificado físico, ningún rol administrativo puede entrar aunque conozcan la contraseña.

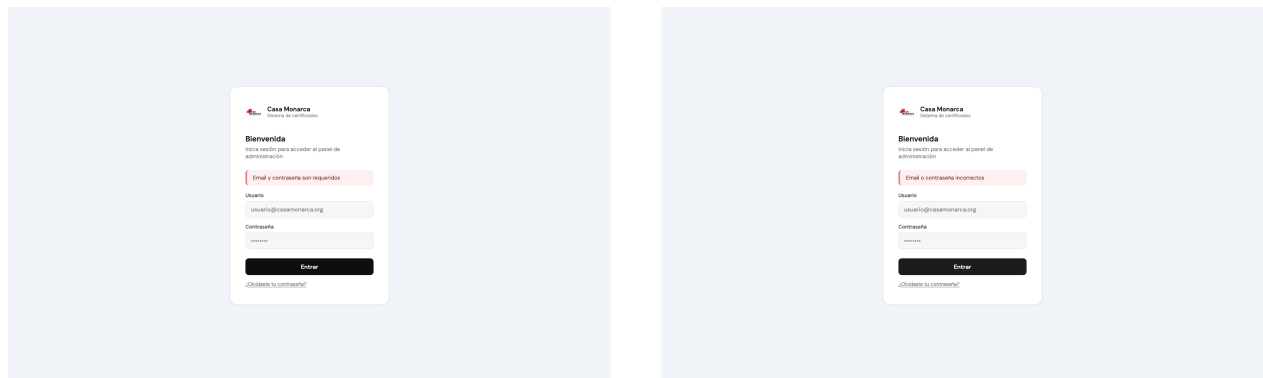


Figura 2: Pantalla de inicio de sesión y mensaje de error ante credenciales incorrectas.

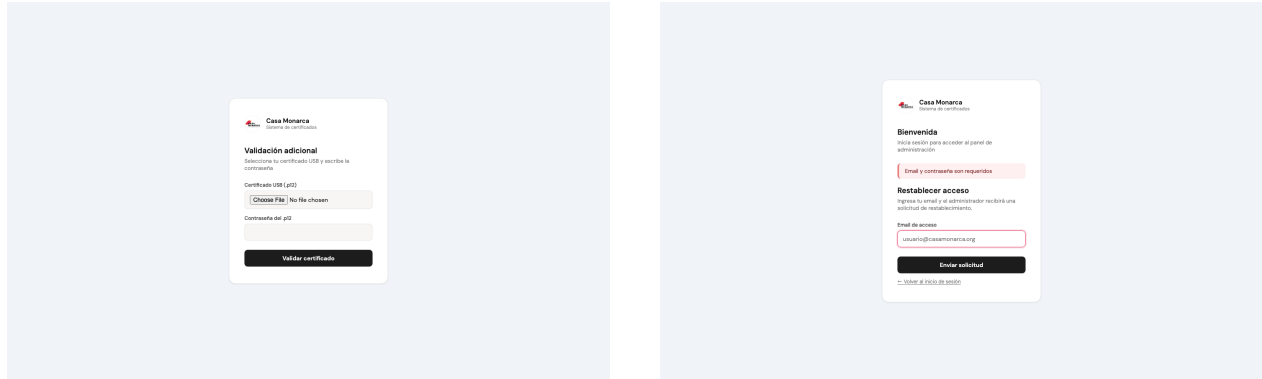


Figura 3: Validación del certificado .p12 desde USB (izquierda). Formulario de restablecimiento de contraseña (derecha).

6.2 Interfaces diferenciadas por rol

Algo que el profesor recalcó desde las primeras sesiones es que cada perfil debería ver una ventana diferente al iniciar sesión. No solo cambian los permisos internos, sino también la experiencia visual. Esto mejora tanto la seguridad como la facilidad de uso, dado que cada usuario interactúa únicamente con las funcionalidades que le corresponden.

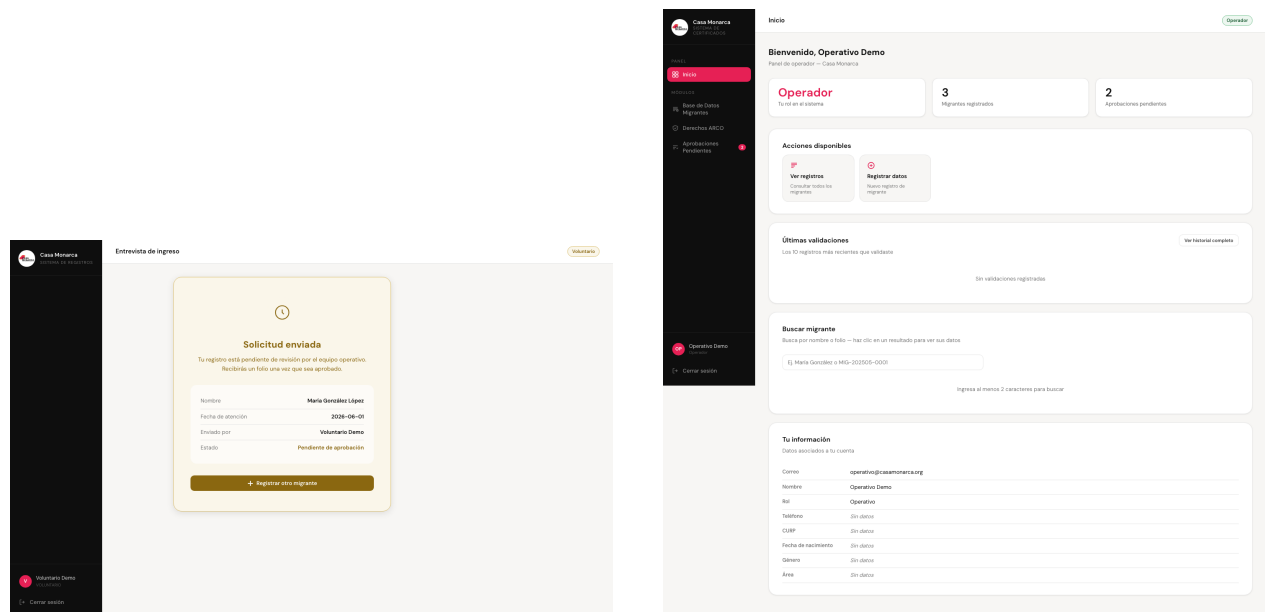


Figura 4: Confirmación de solicitud enviada por el Voluntario (izquierda). Panel de inicio del Operativo (derecha).

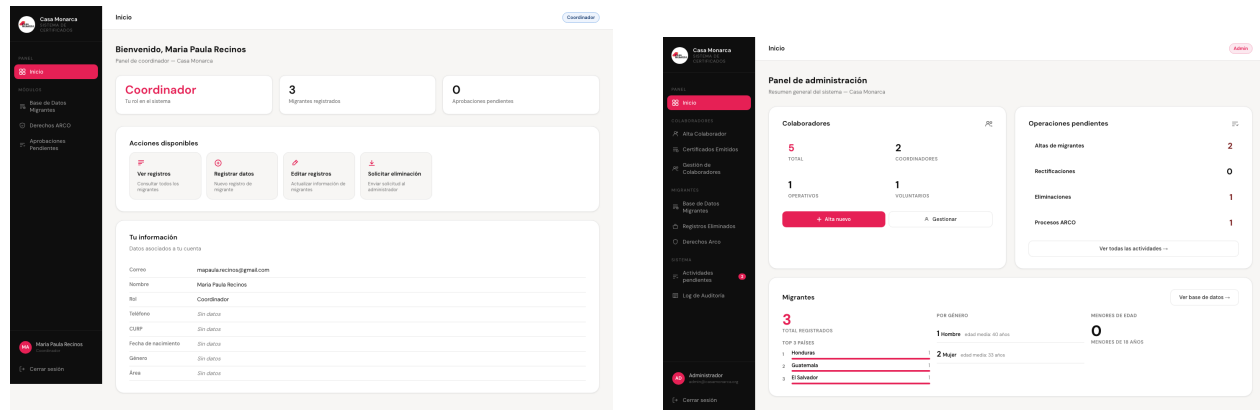


Figura 5: Panel del Coordinador (izquierda) y panel del Administrador (derecha). Cada rol ve métricas y acciones exclusivas de su nivel.

Cadena de custodia con multi-firma ECDSA

Una de las características que más nos enorgullece del sistema es la cadena de custodia criptográfica. Cuando se registra un nuevo expediente de migrante, el proceso requiere tres firmas digitales ECDSA P-256 de tres actores distintos. Esto garantiza, de forma matemática, que ningún actor puede actuar de forma unilateral. Este diseño fue motivado directamente por el incidente previo en Casa Monarca donde un solo colaborador pudo eliminar información sin dejar rastro.

El flujo funciona así. Primero el Voluntario captura el expediente y al enviar firma con su clave privada. Después el Operativo revisa la consistencia y si aprueba agrega su propia firma. Finalmente el Coordinador realiza la autorización final. Las tres firmas se calculan de la siguiente forma:

```
firma_vol = ECDSA.sign(H(expediente + timestamp))
firma_op = ECDSA.sign(H(expediente + firma_vol))
firma_coord = ECDSA.sign(H(expediente
+ firma_vol + firma_op))
```

La tabla `solicitudes_registro_migrante` guarda para cada solicitud las tres firmas, las tres claves públicas y los tres mensajes firmados originales. Todo puede verificarse de forma independiente desde el panel de administración.

Base de Datos Migrantes

Información de personas atendidas por Casa Monarca

FECHA DE ATENCIÓN DESDE: dd/mm/yyyy HASTA: dd/mm/yyyy PAÍS DE ORIGEN: Ej Honduras GRUPO DE ATENCIÓN: Ej solicitante Descargar Excel

Solicitudes de eliminación pendientes 2

Maria González López MIG-202606-0001
Solicitado por mapaula.recinos@gmail.com: 2026-06-02
"Registro duplicado: la misma persona fue capturada dos veces el mismo día."

CADENA DE FIRMAS

PASO	ACCIÓN	RESPONSABLE	FECHA
Paso 1	Solicitud enviada	mapaula.recinos@gmail.com	2026-06-02
Paso 2	Aprobación administrador	Pendiente...	—

Rechazar Aprobar y eliminar

Juan Carlos Pérez MIG-202606-0002 ARCO
Solicitado por mapaula.recinos@gmail.com: 2026-06-02
"Cancelación ARCO: el migrante solicitó ejercer su derecho de cancelación conforme a la LFPDPPP."

CADENA DE FIRMAS

PASO	ACCIÓN	RESPONSABLE	FECHA
Paso 1	Solicitud enviada	mapaula.recinos@gmail.com	2026-06-02
Paso 2	Aprobación administrador	Pendiente...	—

Rechazar Aprobar y eliminar

Buscar por folio, nombre...

FOLIO	NOMBRE	PAÍS DE ORIGEN	GRUPO DE POBLACIÓN	FECHA DE ATENCIÓN	GÉNERO	ACCIONES
MIG-202606-0003	Ana Sofía Hernández	El Salvador	Adulto (18-59 años)	2026-06-01	Mujer	Editar Eliminar
MIG-202606-0002	Juan Carlos Pérez	Guatemala	Adulto (18-59 años)	2026-06-01	Hombre	Editar Eliminar
MIG-202606-0001	Maria González López	Honduras	Adulto (18-59 años)	2026-06-01	Mujer	Editar Eliminar

Figura 6: Vista del Administrador con la base de datos de migrantes, solicitudes de eliminación pendientes y la cadena de firmas visible (Paso 1 y Paso 2).

Módulo de Derechos ARCO

El sistema implementa un flujo jerárquico para atender los Derechos ARCO cumpliendo con la LFPDPPP. Es importante recordar, como decía el profesor en el anuncio del 20 de mayo, que hay que asumir que los beneficiarios carecen de dispositivos electrónicos propios por la naturaleza de su condición, por tanto el ejercicio de estos derechos se realiza a través de los colaboradores.

Para el Acceso, el Operativo busca el expediente del migrante y lo presenta en pantalla. El sistema genera una carta imprimible con los datos, folio, fecha y referencia a la LFPDPPP. Todo queda registrado como evento `arco_acceso`. Para la Rectificación, el Operativo registra los cambios solicitados en la tabla `solicitudes_arco_rect`, el Coordinador revisa y puede aprobar o rechazar.

La Cancelación es el flujo que requiere más seguridad dado que implica eliminación física de datos. El Operativo inicia la solicitud, el Coordinador la revisa y si aprueba firma criptográficamente con su clave EC P-256, la solicitud firmada pasa al Administrador quien verifica la firma y ejecuta la eliminación. La tabla `historial_eliminaciones` conserva folio, quién solicitó, quién firmó y quién ejecutó. La Oposición sigue el mismo flujo.

Acceso a datos - Derecho ARCO

CASA MONARCA
Alianza para Personas Migrantes - Honduras, S.L.

2 de junio de 2026

EJERCICIO DEL DERECHO DE ACCESO - DERECHOS ARCO
En respuesta a la solicitud de acceso a datos personales con folio: MIG-202606-0003, se presenta la información registrada en nuestros sistemas:

Nombre completo	María González López
Fecha de atención	2026-06-01
País de origen	Honduras
Departamento / Estado	Cordoba
Ethnicidad	Mestizo
Estado civil	Adelanta
Fecha de nacimiento	1999-03-15
Grupo de población	Adulto (18-59 años)
Teléfono de contacto	+504 9876 5432

Información confidencial protegida conforme a la Ley Federal de Protección de Datos Personales en Posesión de las Particulares (LFPDPPP). Casa Monarca - Documento generado el 2 de junio de 2026

Historico de solicitudes ARCO
Todos los registros de solicitudes de acceso y cancelación registrados

TIPO	FOLIO	MOVIMIENTO	SOLICITADO POR	FECHA	ESTADO	REVISADO POR	FECHA
Cancelación firmada	2026-06-01	Juan Carlos Pérez	miguel@casamonarca.com	2026-06-02	Pendiente		

Figura 7: Carta imprimible del Derecho de Acceso ARCO con datos del migrante y referencia a la LFPDPPP. Vista del Operativo (izquierda) y del Coordinador con histórico de solicitudes (derecha).

Base de Datos Migrantes

Información de personas atendidas por Casa Monarca

FECHA DE ATENCIÓN DESDE: dd/mm/yyyy HASTA: dd/mm/yyyy PAÍS DE ORIGEN: Ej. Honduras GRUPO DE ATENCIÓN: Ej. solicitante Descargar Excel

Mis solicitudes de eliminación pendientes

Solicitar eliminación

Estás solicitando al administrador la eliminación del registro de Ana Sofia Hernández. El registro no se eliminará hasta que el administrador lo apruebe.

MOTIVO DE LA SOLICITUD *

Explica por qué se debe eliminar este registro...

Cancelar Enviar solicitud

FOLIO	NOMBRE	PAÍS DE ORIGEN	GRUPO DE ATENCIÓN	FECHA DE ATENCIÓN	GÉNERO	ACCIONES
MIG-202606-0003	Ana Sofia Hernández	El Salvador	Adulto (18-59 años)	2026-06-01	Mujer	Editar Solicitar eliminación
MIG-202606-0002	Juan Carlos Pérez	Guatemala	Adulto (18-59 años)	2026-06-01	Hombre	Editar Solicitar eliminación
MIG-202606-0001	María González López	Honduras	Adulto (18-59 años)	2026-06-01	Mujer	Editar Solicitar eliminación

Figura 8: Modal de solicitud de eliminación. El Coordinador debe especificar el motivo antes de enviar al Administrador.

Antes de completar cualquier registro, el sistema presenta un Aviso de Privacidad y Términos y Condiciones. La aceptación queda registrada con checkbox, timestamp y usuario responsable de la captura, generando así evidencia digital del consentimiento informado.

Log de auditoría

Cada operación del sistema queda registrada en la tabla `log_certificados`. El campo `ENUM` acepta más de 30 tipos de eventos. Dentro de estos se encuentran eventos de autenticación (`exitoso`, `fallido`), de certificados (`cert_emitido`, `cert_revocado`), de gestión (`rol_modificado`, `pwd_cambiada`), de registro (`registro_migrante`) y de derechos ARCO (`arco_acceso`, `arco_cancel_coord_firmada`), entre muchos más. El log es `append-only`, es decir que una vez escrito no puede modificarse ni eliminarse. Los administradores pueden descargar reportes completos en Excel desde el panel.

Log de Auditoría

Últimos 50 eventos del sistema (emisión, revocación, logins, intentos fallidos)

FECHA DESDE: dd/mm/yyyy HASTA: dd/mm/yyyy [Descargar Excel](#)

FECHA	USUARIO	ROL	EVENTO	DETALLE
Tue, 02 Jun 2026 00	admin@casamonarca.org	admin	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	mapaula.recinos@gmail.com	coord	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	operativo@casamonarca.org	op	ARCO ACCESO ARCO	Acceso ARCO id=1 folio=MIG-202606-0001
Tue, 02 Jun 2026 00	operativo@casamonarca.org	op	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	voluntario@casamonarca.org	voluntario	REGISTRO MIG ENVIADO VOLUNTARIO	Ticket #2: Maria González López - País: Honduras
Tue, 02 Jun 2026 00	voluntario@casamonarca.org	voluntario	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	wrong@test.com	-	LOGIN FALLIDO	Credenciales incorrectas
Tue, 02 Jun 2026 00	admin@casamonarca.org	admin	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	mapaula.recinos@gmail.com	coord	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	operativo@casamonarca.org	op	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	voluntario@casamonarca.org	voluntario	REGISTRO MIG ENVIADO VOLUNTARIO	Ticket #1: Maria González López - País: Honduras
Tue, 02 Jun 2026 00	voluntario@casamonarca.org	voluntario	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	wrong@test.com	-	LOGIN FALLIDO	Credenciales incorrectas
Tue, 02 Jun 2026 00	voluntario@casamonarca.org	-	LOGIN FALLIDO	Credenciales incorrectas
Tue, 02 Jun 2026 00	admin@casamonarca.org	admin	LOGIN EXITOSO	
Tue, 02 Jun 2026 00	wrong@test.com	-	LOGIN FALLIDO	Credenciales incorrectas

Figura 9: Log de auditoría mostrando eventos en tiempo real. Se observan logins exitosos y fallidos, registros de migrantes enviados por voluntarios y accesos ARCO realizados por operativos.

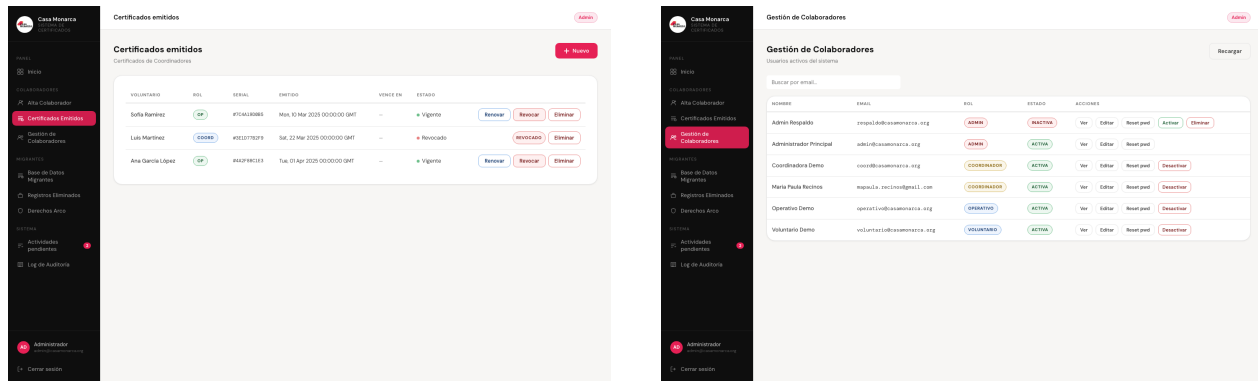


Figura 10: Certificados emitidos con estados Vigente y Revocado (izquierda). Gestión de colaboradores con acciones por usuario (derecha).

The screenshot shows the 'Alta Colaborador' form in the Casa Monarca system. The form is divided into three steps: 1. Datos, 2. Certificado, and 3. Entrega en USB. The 'Datos' step is currently active, showing fields for personal data (Nombre completo, Fecha de nacimiento, Edad, CURP, Teléfono) and organizational data (Rol, Área, Observaciones). A 'Generar certificados' button is at the bottom. The form also includes a sidebar with navigation options and a user profile section at the bottom left.

Figura 11: Alta de colaborador con flujo de tres pasos: Datos, Certificado y Entrega en USB. Se genera el .p12 con contraseña temporal que se muestra una sola vez.

Protocolos para escenarios críticos

El sistema contempla cinco escenarios críticos. Ante un cambio de Administrador, se activa el Admin de Respaldo, se emite nuevo .p12, se revoca el certificado saliente y se desactiva la cuenta. Existe un script bootstrap protegido físicamente como llave maestra. Ante pérdida o

robo de USB, la revocación es instantánea desde el panel, al presentar el .p12 revocado el sistema devuelve error 403 antes de cargar nada. Si un usuario olvida su contraseña, solicita reset desde el login, el Admin aprueba y se genera contraseña temporal que se comunica por canal externo. Para baja de personal, se revoca el certificado y se desactiva la cuenta, pero los registros y el log se conservan para trazabilidad. Y si un certificado expira, el sistema lo marca automáticamente y el Admin emite uno nuevo.

Pruebas del sistema

Se diseñó una tabla formal de casos de prueba cubriendo autenticación, login y autorización por roles. Cada caso tiene enlace a evidencia en Google Drive con capturas de pantalla. En autenticación se verificó que el sistema bloquea sin certificado, que acepta certificados válidos, que detecta revocados, que rechaza los de otras CAs, y que cada certificado solo funciona con su usuario específico. En login se validó el acceso correcto, el cambio forzado de contraseña temporal, la longitud mínima de 8 caracteres, el rechazo con contraseña incorrecta y el bloqueo por intentos fallidos. En roles se confirmó que cada usuario ve solo lo que le corresponde y no puede acceder a funciones de niveles superiores.

The screenshot displays the 'Actividades Pendientes' (Pending Activities) section of the Casa Monarca Sistema de Certificados Admin interface. The interface is in Spanish and shows a sidebar with navigation options like 'Inicio', 'COLABORADORES', 'MIGRANTES', and 'SISTEMA'. The main content area is titled 'Actividades pendientes' and includes a sub-header 'Solicitudes de colaboradores que requieren acción del administrador'. It features a table for 'Solicitudes de registro de migrante' with columns for 'NOMBRE', 'PAÍS', 'ENVIADO POR', 'ESTADO', 'PENDIENTE DE', and 'ACCIONES'. The table lists two entries for 'María González López' from Honduras, both with a 'PENDIENTE OP' status. Below this, there is a section for 'Solicitudes de eliminación' with columns for 'FOLIO', 'MIGRANTE', 'SOLICITADO POR', 'ESTADO', and 'FECHA', listing two entries for 'María González López' and 'Juan Carlos Pérez'. At the bottom, there is a section for 'Solicitudes ARCO' which is currently empty. The interface also includes a 'Cerrar sesión' button and a 'Selección a menos un ticket' button.

Figura 12: Actividades pendientes del Administrador: solicitudes de registro de migrante con opción de aprobar o rechazar, y solicitudes de eliminación con firma digital.

Alineación con los ODS

El proyecto se alinea con tres Objetivos de Desarrollo Sostenible de la Agenda 2030. Con respecto al ODS 3 (Salud y Bienestar), el sistema protege datos médicos y personales de personas vulnerables, el cifrado y el control de acceso previenen que datos sensibles sean

expuestos. En cuanto al ODS 10 (Reducción de Desigualdades), el sistema garantiza acceso justo a servicios para migrantes y fue diseñado para operarse sin conocimientos técnicos, de manera que la interfaz intuitiva reduce la brecha digital en lugar de ampliarla. El ODS 16 (Paz, Justicia e Instituciones Sólidas) se refleja en la trazabilidad total del log inmutable, el control jerárquico y el cumplimiento de la LFPDPPP. La cadena de multi-firma ECDSA garantiza que ninguna persona actúe unilateralmente sobre los datos de un migrante.

Reflexión ética

Cuando se habla de implementar protocolos que tomen como base la criptografía de clave pública, puntualmente nosotros como ingenieros en ciencia de datos y matemáticas pensamos que su seguridad puede depender meramente de su eficiencia matemática. Pese a eso, la ética no es parte del algoritmo creado, sino de cómo se implementa, para quién y las posibles consecuencias. El objetivo de Guardián Monarca no se reduce a “proteger datos”, sino a proteger personas. No implementamos la criptografía solo porque es avanzada, sino porque se muestra como una solución para la reducción de riesgos reales para los usuarios. Esto me hace reflexionar sobre lo que decían Vallor y Rewak (2018), la ética debe centrarse en el impacto humano, no solo en lo técnico. Si desarrollamos un sistema bueno pero complejo, no sería suficiente, porque al ser complicado nadie lo usaría correctamente y en lugar de presentarse como un beneficio sería un riesgo.

Esto conecta con el principio de autonomía, porque muchos sistemas fallan en ella. Aunque se usa criptografía, si el usuario no entiende nada ni tiene control real puede mostrarse como un riesgo. Por ello diseñamos interfaces claras donde el operativo sabe cuando firma digitalmente y el migrante acepta explícitamente el aviso de privacidad. Como decía Bilbao (2013), la ética profesional implica responsabilidad social, no solo cumplimiento técnico. Nuestro sistema fue diseñado para ser independiente de tecnología costosa, no excluir a usuarios con menor alfabetización digital y poder crecer sin comprometer los datos de las personas. En definitiva, la seguridad debe ser para todos, no puede ser excluyente ni depender de infraestructura inaccesible.

Mejoras para versión 2

Durante el desarrollo identificamos mejoras que podrían implementarse a futuro. Homogeneizar la CA a EC P-384 eliminando RSA por completo. Migrar sesiones a Redis para mayor escalabilidad. Implementar migraciones con Alembic. Fortalecer la validación de contraseñas con políticas más estrictas que incluyan mayúsculas, caracteres especiales e historial. Y desplegar con nginx como reverse proxy para habilitar mTLS completo, dado que el servidor de desarrollo de Flask no soporta conexiones TLS concurrentes por ser single-threaded.

Conclusiones

Guardián Monarca demuestra que es posible construir un sistema de gestión de identidades digitales con seguridad criptográfica real para una organización sin presupuesto tecnológico. La combinación de una PKI propia con certificados X.509, firmas ECDSA sobre curvas elípticas

P-256, control de acceso por roles y un log inmutable garantiza que la información de las personas migrantes esté protegida en cada capa.

La implementación de los Derechos ARCO con flujo jerárquico y firma digital en cada paso cumple con la LFPDPPP y establece un estándar de trazabilidad que permite a Casa Monarca demostrar ante cualquier autoridad que los datos se gestionan de forma responsable. La cadena de custodia con multi-firma ECDSA es la característica que mejor refleja la conexión entre el álgebra moderna y la seguridad práctica: tres actores distintos deben firmar cada expediente con sus claves elípticas, lo cual hace matemáticamente imposible que un solo individuo registre, apruebe y autorice sin dejar evidencia criptográfica verificable. En definitiva, el proyecto no es solo una solución técnica, sino una aplicación directa de los conocimientos de álgebra moderna al servicio de la dignidad humana.

Repositorio

Github Gestor Monarca: <https://github.com/PaoGaleazzi/reto-casa-monarca>

Referencias bibliográficas

1. ACNUR. (2025). Monitoreo de protección. <https://www.acnur.org/mx>
2. Bilbao, G., Fuertes, J., & Guibert, J. M. (2013). Ética para ingenieros. Desclée De Brouwer.
3. Cooper, D., et al. (2008). RFC 5280: Internet X.509 PKI Certificate and CRL Profile. <https://www.rfc-editor.org/rfc/rfc5280>
4. Judson, T. W. (2024). Abstract Algebra: Theory and Applications. <http://abstract.ups.edu/aata/>
5. Menezes, A., van Oorschot, P., & Vanstone, S. (1997). Handbook of Applied Cryptography. CRC Press.
6. NIST. (2013). FIPS 186-4: Digital Signature Standard (DSS). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.FIPS.186-4>
7. OIM. (2025). Boletín de estadísticas migratorias para México 2024. <https://mexico.iom.int>
8. Otero Fadul, D. (2026). Uso de álgebras modernas para seguridad y criptografía. Notas de clase, Tecnológico de Monterrey.
9. Python Software Foundation. (2024). cryptography: X.509 certificates. <https://cryptography.io/en/latest/x509/>
10. Rescorla, E. (2018). RFC 8446: TLS Protocol Version 1.3. <https://www.rfc-editor.org/rfc/rfc8446>

11. Vallor, S., & Rewak, W. J. (2018). An introduction to cybersecurity ethics. Markkula Center for Applied Ethics.